WHAT YOUR BUSINESS REALLY PAYS

THE HIDDEN COST OF FREE BUSINESS TOOLS

How Free Apps, Extensions and Online Platforms **Use Your Business Data**

BUSINESS MODELS | DATA COLLECTION | EXTENSIONS | SAFER ALTERNATIVES

ZIRLANDIA MILKOVIC

WHAT YOUR BUSINESS REALLY PAYS

THE HIDDEN COST OF FREE BUSINESS TOOLS

How Free Apps, Extensions and Online Platforms Use Your Business Data

ZIRLANDIA MILKOVIC

The Hidden Cost of Free Business Tools
How Free Apps, Extensions and Online Platforms Use Your Business Data

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 30 October 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional.

Contents

START HERE

Educational Disclaimer 4
Introduction: The Price Tag You Cannot See 4
Who This Book Is For 6
How to Use This Book 6
The One-Page Free Tool Check 8

CHAPTERS

1. Nothing Is Really Free 9
2. What Free Tools Collect 15
3. Where Your Data Goes 19
4. Browser Extensions: The Biggest Blind Spot 24
5. Free Platforms, Converters and AI Tools 31
6. Shadow IT: The Tools Your Team Brought 36
7. What the Law Expects of You 39
8. Reading the Fine Print in Fifteen Minutes 44
9. Safer Alternatives 49
10. A Simple Tool Policy 54
11. When a Free Tool Goes Wrong 58
12. Your 30-Day Free Tool Plan 62

CLOSING

Conclusion: Pay Attention 65

APPENDICES

Appendix A: Free Tool Register 66
Appendix B: Browser Extension Audit 67
Appendix C: Fine-Print Checklist 68
Appendix D: One-Page Tool Policy Template 69
Appendix E: Free-versus-Paid Questionnaire 71
Appendix F: Exit Plan 72
Appendix G: Free Tool Incident Log 73

BACK MATTER

Glossary 74
A Note on GDPRGard.eu 75
About the Author 76
Notes and Sources 77

Educational Disclaimer

This book is practical, educational guidance for small and medium-sized businesses. It is not legal, security or data-protection advice, and it does not create a professional relationship between the author and the reader.

Data-protection law, consumer law, contract law and platform rules differ by country, apply differently to different businesses, and change quickly. Free products change their terms, features and owners without notice. Check the current position with a qualified adviser or your regulator before relying on anything here for a decision that matters.

Following the steps in this book may reduce your risk. It cannot guarantee that a tool will not misuse or lose your data, or that you will meet every legal duty. Checklists and templates are starting points to adapt, not finished legal documents. Companies and products are named only to illustrate public, reported events or categories of tool. Naming a product is not an accusation, and not naming one is not an endorsement.

Every business, person and product used in a worked example is **fictional** and is labelled as such. Where the book describes a real case or rule, it is sourced in the notes at the back.

Introduction: The Price Tag You Cannot See

Somewhere in your business, right now, a free tool is doing a job for you.

It might be a PDF converter your bookkeeper found at midnight, a meeting-notes app that joins your calls, a browser extension that checks your grammar, a free design tool, a free survey form, a free VPN on a staff phone, or a free AI assistant that a team member pastes client emails into. Each saved somebody time. None sent an invoice. So none of them was ever reviewed, approved or written down.

Free is not the same as costless. Software costs money to build, host, secure and support. When the user does not pay, the money has to come from somewhere else: from a later upgrade, from advertisers, from partners, from the data the product collects, or from investors who are betting that the user base will be worth more than it costs to serve. Often the price is perfectly fair. Sometimes it is not, and sometimes you only discover which when something goes wrong.

You may have heard the saying that *if you are not paying, you are the product*. It is a useful warning and a poor rule. Plenty of free tools are honest, well-run and funded by paying customers upstairs. Plenty of paid tools collect more than they should. What matters is not the price. It is whether you **know the business model, know what the tool collects, and have decided on purpose** that the trade is worth it.

For a business, that decision is not only personal. The data in your tools is rarely just yours. It includes your customers' names, emails and orders, your suppliers' prices, your staff's details, your contracts and your unpublished plans. If a free tool mishandles it, you are the one who has to explain it to the customer, the client or the regulator. Under data-protection law, "we used a free app" is not a defence. It is closer to the opposite.

This book helps you take back that decision. It follows one plain idea in every chapter:

> **The rule.** A free tool is a supplier. Treat it like one: know what it takes, know what it does with it, and know how to leave.

You will learn how free software makes money, what it collects, where your data can end up, why browser extensions deserve special suspicion, what the law expects of you, how to read terms in fifteen

minutes, how to choose safer alternatives, and how to run a simple policy that keeps the useful free tools and removes the risky ones. A 30-day plan at the end puts it all to work.

You do not need to give up free tools. You need to stop using them blind.

Who This Book Is For

This book is for you if you run, manage or advise a small or medium-sized organisation in Europe or the UK and any of the following is true:

- Your team uses free or freemium apps, online converters, templates, plugins or platforms for work, and you could not list them all.
- Staff install browser extensions on work computers, or use their own browser profiles for work.
- Team members paste business or customer information into free AI chatbots, transcription tools or writing assistants.
- You use a consumer account (a personal email, a personal cloud drive, a free messaging app) for business purposes.
- A client, insurer or auditor has started asking which tools handle their data, and you are not certain of the answer.

It is written for owners, managers, operations leads, office managers, freelancers who handle client data, and the person who has been handed "IT" on top of their real job. It assumes no technical background. Technical terms are explained when they first appear and collected in the glossary.

It is **not** a guide for large enterprises with security teams, procurement departments and managed device fleets. Many of the ideas still apply, but you will need heavier controls than a small business can build from a spreadsheet and a one-page policy.

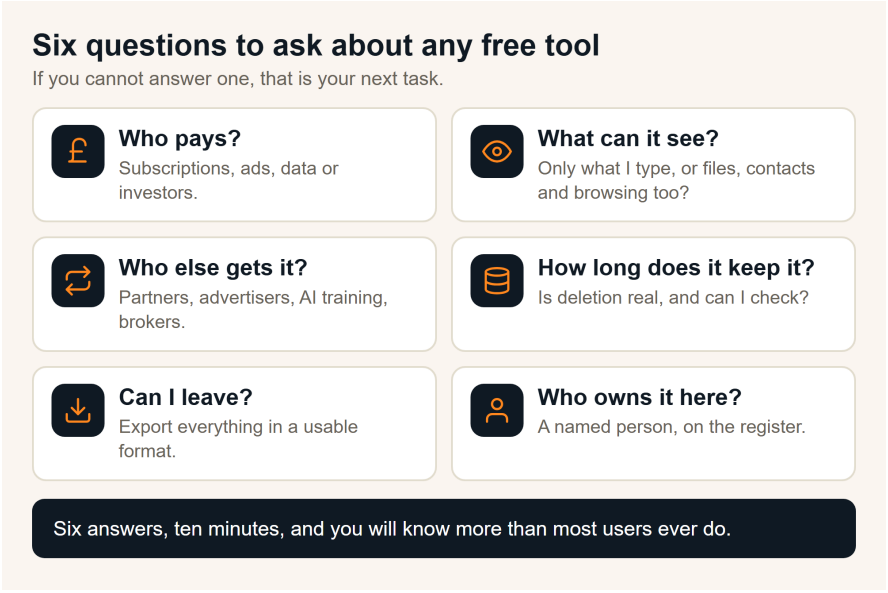
How to Use This Book

You can read the book front to back in an evening, or use it as a manual. Chapters 1 to 3 explain the economics and the data. Chapters 4 to 6 look at the three places free tools hide: browser extensions, free online platforms and AI tools, and the tools your team brought in without telling you. Chapters 7 and 8 cover the law and the fine print. Chapters 9 to 11 are the practical core: **choose**, **govern**, **respond**. Chapter 12 is a 30-day plan.

Look for these markers:

- **The rule.** A principle worth remembering, set in a dark panel.
- **Fictional.** A worked example using invented people and businesses. The running example is Marlowe & Finch, an invented nine-person brand studio.
- Check boxes (☐). A step you can tick off. Where a line is blank, write on it.

The appendices contain ready-to-use templates: a free-tool register, a browser-extension audit, a fine-print checklist, a one-page tool policy, a free-versus-paid questionnaire, an exit plan and an incident log. Copy them into a spreadsheet or print them.



The six questions to ask about any free tool

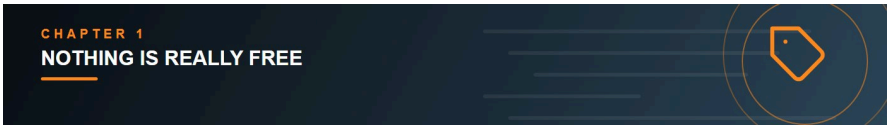
The One-Page Free Tool Check

Before you adopt a free tool, or when you review one you already use, ask these questions. If you cannot answer one, that is your next task.

- ☐ How does this company make money? (Subscriptions, advertising, data, investors?)
- ☐ What data will the tool see: only what I type, or also files, contacts, browsing, location and device details?
- ☐ Will it see **other people's** data (customers, staff, suppliers)?
- ☐ Do the terms allow it to use my content to train AI, build profiles or share with partners?
- ☐ Is there a business version with a data processing agreement, and what does it cost?
- ☐ Where is the data stored, and who else can access it?
- ☐ Can I export everything and delete it if I leave?
- ☐ Who in my business **owns** this tool, and is it on our register?
- ☐ What happens if the company is sold, changes its terms or shuts down?
- ☐ If I pay a modest fee instead, what do I get that free does not give me?

CHAPTER 1

Nothing Is Really Free



> **Fictional.** Marlowe & Finch, its staff and every tool below are invented for teaching. They are not real businesses or incidents.

Marlowe & Finch is a nine-person brand and marketing studio. Nadia, the founder, is proud that the studio runs on almost nothing: a free design tool, a free project board, a free PDF converter, a free e-signature app, a free video-call recorder that writes meeting notes, and a free browser extension that checks everyone's grammar. The software bill last year was under four hundred pounds.

Then a client, a regional charity, sends a supplier questionnaire. *Which tools process our data? Where is it stored? Do you have data processing agreements with each provider? Do any of them use our content to train AI?*

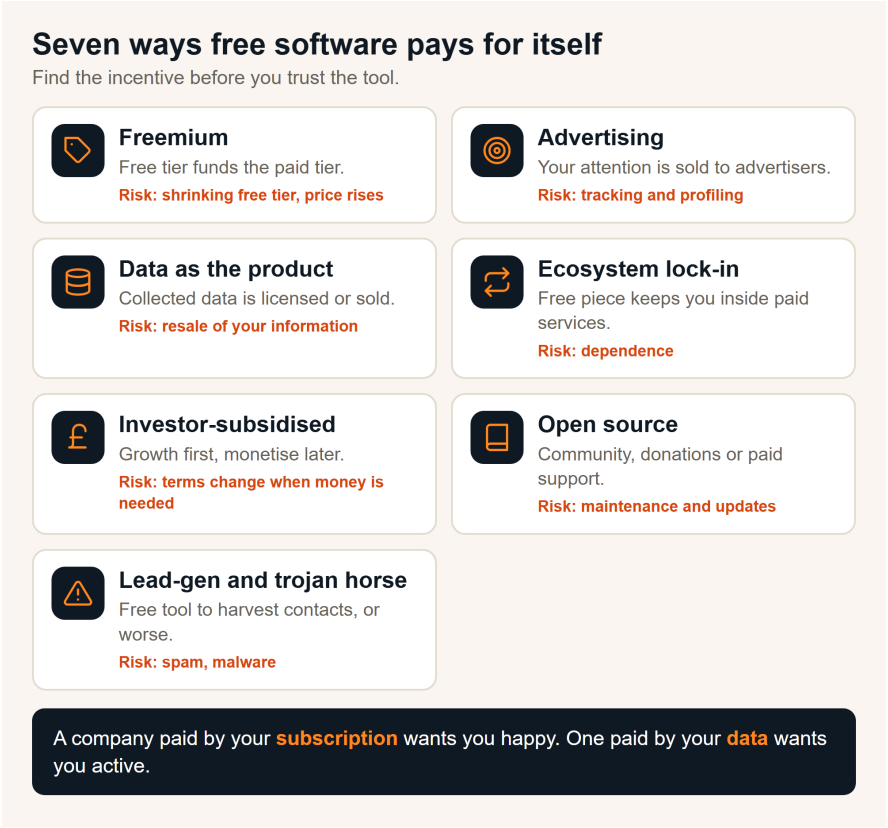
Nadia opens a spreadsheet and starts listing. By the time she has reached nineteen tools she realises that she has not read the terms of any of them, that she does not know who installed six of them, and that the meeting recorder has been transcribing the charity's own calls for four months.

None of those tools was reckless on its own. The risk was the **absence of a decision**. Nobody had asked how each one paid for itself, and so nobody knew what it was taking in exchange.

A free tool still has a price. Somebody just has to find it

Who pays for "free"

Software is expensive. Servers, security, support and engineers cost real money every month, whether or not a customer pays. When a product is free to you, one of the following is paying instead.



Seven ways free software pays for itself

1. Freemium. A free tier brings you in; a paid tier funds the company. Your risk is mostly dependency: the free tier shrinks, the price rises, or the feature you rely on moves behind a paywall. Freemium vendors usually have a real business and an incentive to keep customers' trust.

2. Advertising. The product is free because advertisers pay for access to its users' attention. To sell attention, the company collects behaviour, interests and identifiers. This model sits behind most free consumer apps and many free web services.

3. Data as the product. Some tools exist mainly to collect data that is valuable in itself: browsing activity, location, purchase patterns, contacts. The collected data is aggregated, "anonymised" and sold or licensed. In the worst cases the free product is a front for collection.

4. Ecosystem and lock-in. A large company gives away one product to keep you inside a wider ecosystem of paid products, advertising or cloud services. The data you create keeps you there.

5. Venture-subsidised growth. Investors pay for the product while the company grows its user base. The plan is to make money later, by raising prices, adding ads, selling the company or finding new uses for the data. The terms you accepted at the start are not a promise about the terms you will have then.

6. Open source and community. Some free software is genuinely free: built by volunteers, funded by donations, or backed by companies that sell support or hosting. Open source is not automatically safe (it still needs updates and review), but it removes the hidden commercial incentive.

7. Lead generation and trojan horses. A free tool exists to collect your contact details and sell you something else, or to carry advertising, bundled software or, in the worst cases, malware. Free converters, "cleaners" and downloaders are common examples.

A single product can mix several of these. A free email service might be ecosystem-funded, advertising-funded and freemium at once. The point of the list is not to label the tool. It is to find the *incentive*. A company that earns money from your subscription wants you to stay happy. A company that earns money from your data wants you to stay **active**.

> **The rule.** Ask of every free tool: *who is paying, and what are they paying for*? If you cannot find the answer, assume your data is part of it.

Free is not the same as dishonest

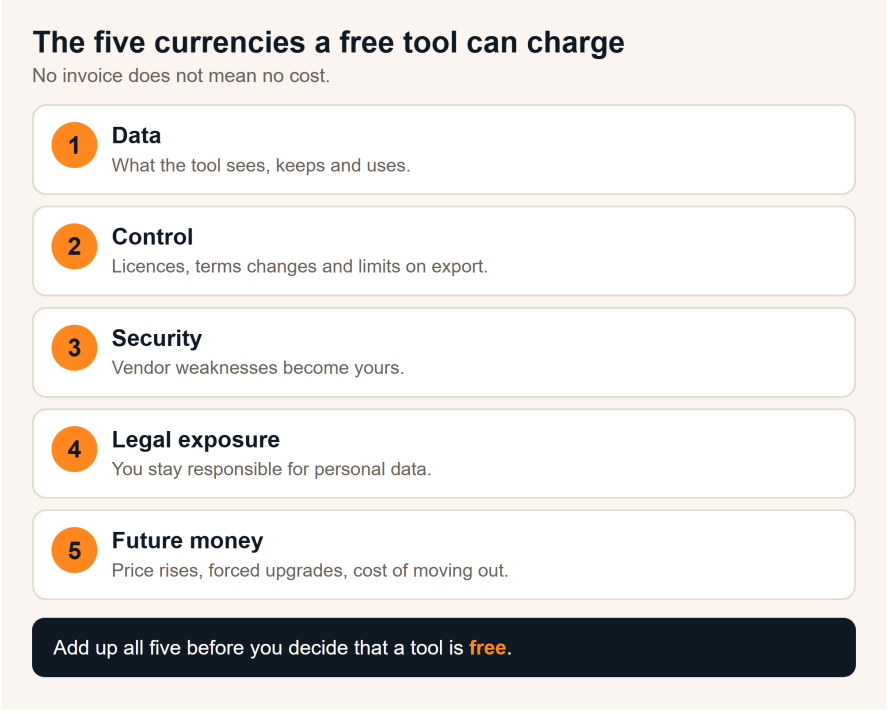
It is worth being fair. Most free products are not traps, and many small businesses depend on them to survive. A well-run freemium tool with a clear privacy policy, a business tier and a data processing agreement is often safer than an undocumented paid product bought on a whim.

The trouble starts in three places:

- **Mismatch.** The free tier is designed for individuals, but you use it for business. Consumer terms often give the company wider rights to your content than the business tier does, and may not include the contractual protections the law requires when a supplier handles personal data for you.
- **Drift.** The product you chose is not the product that exists a year later. Terms change, owners change, and features that collect more are added.
- **Invisibility.** You do not know the tool is there. Chapter 6 deals with the tools your team adopted without you.

The five currencies you pay in

Even when no money moves, free tools charge you in other currencies. Counting them is the first step in judging whether the trade is fair.



The five currencies a free tool can charge you in

1. **Data.** What the tool sees, stores and uses: your files, messages, contacts, behaviour and device details.
2. **Control.** Rights you grant: licences over your content, permission to change terms, limits on what you can export.
3. **Security.** Risk you inherit: a weaker vendor can be breached, and a free tool may have no one to call when it happens.
4. **Legal exposure.** Duties that stay with you: when personal data is involved, you remain responsible for how it is handled.
5. **Future money.** The bill that arrives later: price rises, forced upgrades, or the cost of migrating out.

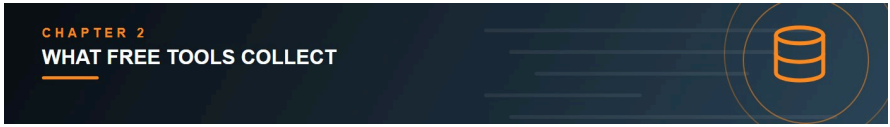
What you will do about it

This book does not ask you to abandon free software. It asks you to do five practical things:

1. **Find** every free tool, extension and platform your business uses.
2. **Understand** how each makes money and what it collects.
3. **Decide** whether the trade is acceptable, tool by tool, with a named owner.
4. **Replace or upgrade** the tools where it is not.
5. **Keep a record** so you can answer the next client, insurer or regulator in an afternoon rather than a month.

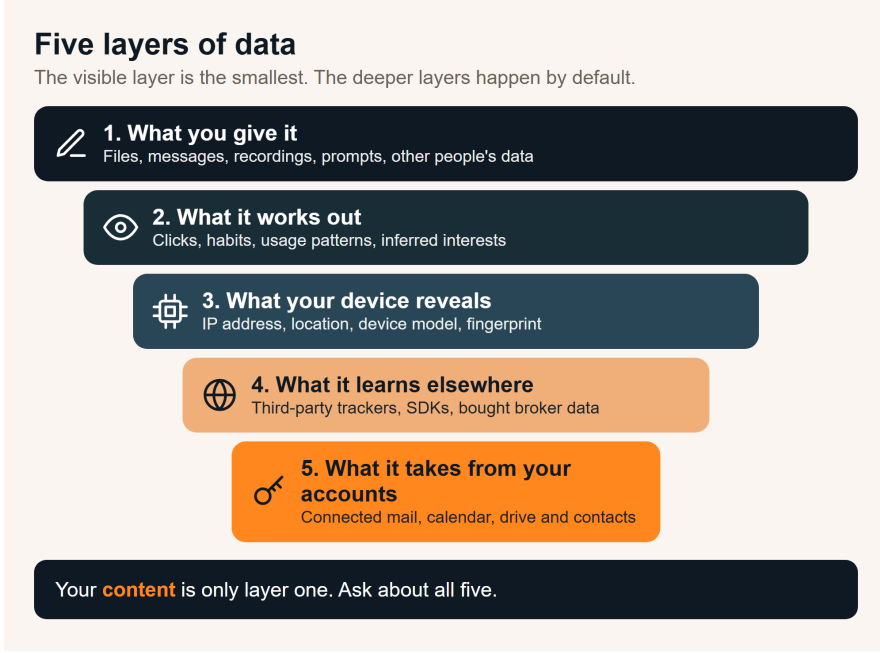
CHAPTER 2

What Free Tools Collect



When Nadia read the meeting recorder's privacy policy for the first time, the list of "information we collect" ran to forty-one items. She had expected a name and an email address.

Most people picture data collection as the things they type in. That is the smallest part. A modern free tool can collect several layers of information, and some layers are collected simply because the tool is running.



Five layers of data a free tool can see

Layer 1: what you give it

This is the content and account information you knowingly provide: your name, email address, company, payment details if any, and above all the **content you put in**. Documents you upload. Messages you write. Recordings of your calls. Prompts you paste into an AI tool. For a business, this layer includes other people's data: every customer name in a spreadsheet, every employee detail in a form, every supplier price in a quote.

Layer 2: what it works out about you

Even if you type nothing personal, a tool builds knowledge by watching: when you log in, how often, what you click, which features you use, how long you stay. This **behavioural** data is the raw material of both product improvement and advertising. A tool may also create **inferences**, such as your likely role, industry or interests, and store those as part of a profile.

Layer 3: what your device reveals

Your device and connection tell a service a surprising amount without any effort: IP address, approximate location, device model, operating system, browser, language, screen size, installed fonts, time zone. Combined, these can act as a **fingerprint** that identifies one device across sites even when cookies are blocked. Mobile apps may also request access to the camera, microphone, contacts, photos, calendar or precise location.

Layer 4: what it learns from other places

Free tools rarely work alone. They may include **third-party code**: analytics libraries, advertising software development kits (SDKs), crash reporters, social media buttons and tracking pixels. Each one is a separate company receiving data about what you do in the tool. The tool's vendor may also buy data from **brokers** to enrich its profile of you, or combine information from your use of its other products.

Layer 5: what it takes from your accounts

Many free tools ask you to "sign in with" another account or to connect your email, calendar, drive or contacts. Each connection hands over a slice of a bigger store. A free scheduling app that can read your whole inbox, or a note-taker that can see every meeting invitation and attendee, may collect more about your clients than you realise.

> **The rule.** The data a free tool collects is limited by two things only: what its code is able to see, and what its terms let it keep. Neither is limited by what you meant to share.

Content versus metadata

Businesses often protect the content of their documents while ignoring the **metadata**: who you communicate with, how often, when, from where, and which files you open. Metadata can reveal a client list, a merger in progress, a staff member's health absence or a job search, without a single document being read. A free tool that collects only metadata can still build a detailed picture of your business.

Personal data of people who never agreed to anything

Your customers did not accept the free tool's terms. Neither did your colleague whose name is in the shared document, nor the supplier whose contact details are in your address book. When a free tool takes in their data on your behalf, it is **your** processing: you decided to use that tool for that purpose. Under data-protection law, that makes you responsible for telling people what you do with their data and for making sure a supplier handling it does so under proper terms (Chapter 7).

A meeting recorder is a good example. It captures the voices, names and opinions of everyone on the call, including people who never signed up and may not know a bot has joined. Recording and transcription tools have faced complaints and lawsuits over exactly this: whether participants were properly informed and whether recordings were used to improve the vendor's own AI models.[3]

How much is too much?

Data-protection law gives a useful test: a tool should collect only what is **adequate, relevant and limited** to what is necessary for the purpose, and keep it no longer than needed.[10] A PDF converter needs the PDF. It does not need your contacts. A grammar checker needs the sentence you are typing. It does not need to see every page you visit.

Apply the same test to every tool. For each one, ask:

- ☐ What does this tool *need* in order to do the job I give it?
- ☐ What does it ask for or collect *beyond* that?
- ☐ Is the extra data used only for my benefit, or also for the vendor's?
- ☐ Can I turn the extras off, and have I?

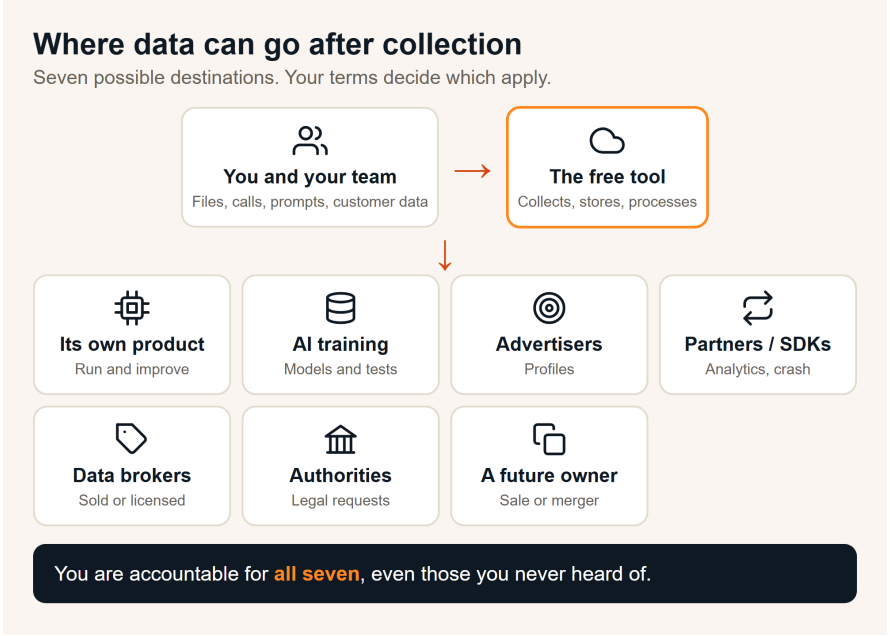
A tool that collects far more than its job requires is telling you something about its business model.

CHAPTER 3

Where Your Data Goes

Collection is the first half of the story. The second half is where the data travels after the tool has it.

Nadia's questionnaire from the charity asked a deceptively simple question: *does any provider use our content to train* AI? It took her two evenings to find that out. The honest answer, for most free tools, is that you have to read the terms, and the terms may have changed since you last looked.



Where data can travel after a free tool collects it

Seven destinations

1. The vendor's own product. The most benign use: operating the service, fixing bugs, preventing abuse. This is normally covered by phrases such as "to provide and improve our services".

2. Product improvement and AI training. Many vendors reserve the right to use content, usage data or both to improve products, including by training machine-learning models. Whether this extends to the **content of your documents, calls and prompts** varies enormously between vendors and between free and paid tiers. It is also one of the areas where terms have been rewritten fastest.

3. Advertising and profiling. Data about behaviour and interests is used to target advertising, on the vendor's own platform or through partners. For business tools, this should be a red flag: an advertising model attached to a tool that holds your client data is a mismatch of incentives.

4. Partners, affiliates and sub-processors. Policies commonly allow sharing with "affiliates", "trusted partners" and "service providers". Some of those are ordinary infrastructure companies. Others are advertising networks or analytics firms. The list of recipients is often published separately and rarely read.

5. Data brokers and resale. Some products sell or license data, in "aggregated" or "anonymised" form, to third parties. Whether the data is genuinely anonymous is the key question; regulators have found examples where it was not.

6. Authorities and courts. Vendors may be required to hand data to law enforcement or regulators. Where the vendor sits, and where it stores data, affects whose law applies.

7. Whoever buys the company. If a vendor is sold, merges or goes bankrupt, your data may travel with it. The privacy policy you accepted may be replaced by the buyer's.

What this looks like in practice

These are not hypothetical. A handful of public cases show how the pattern plays out.

- **A video-meetings platform (2023).** Changes to the company's terms of service appeared to give it broad rights over customer content, including for AI training. After a wave of criticism the company clarified that it would not use audio, video or chat content to train its AI models without customer consent. The episode showed how quickly a business could be bound by wording nobody had read.[1]
- **A file-transfer service (2025).** An update to the terms of a popular file-transfer service gave it a broad licence over uploaded files, including for machine-learning purposes. After user backlash the company withdrew the AI references and said it did not use AI to process content shared through the service.[2]
- **An antivirus company (2014 to 2020).** A subsidiary of a major antivirus vendor collected users' browsing data through its products and sold it to more than a hundred third parties. In 2024 the US Federal Trade Commission ordered the parent to pay $16.5 million and barred it from selling or licensing browsing data for advertising. The regulator said the data was sold in a form that could be linked back to individuals, despite promises of protection.[4]
- **An AI note-taking service (2025).** A class action in California alleged that an AI meeting-transcription service recorded workplace conversations, including those of non-users, and used them to train its models without proper consent. The claims were allegations and the company denied wrongdoing; the point for a small business is how much of a call's content can pass to a vendor by default.[3]

> **The rule.** Terms of service are not a fixed contract with a fixed meaning. They are a moving permission. What a tool may do with your data is whatever its current terms say, not what it said when you signed up.

Why changes matter more than the first reading

Most free tools let the vendor change the terms by posting a notice or by continued use. A change can be as small as a new paragraph or as large as a new licence over your content. Few businesses notice: the email goes to the person who signed up, who may have left. The practical response is not to read every update. It is to **have an owner** for each tool who gets the notices, and a **register** that records the date you last reviewed the terms (Chapter 10).

Retention: the data that stays

Even when a vendor's use is acceptable, the question of **how long** matters. Data you uploaded two years ago for a one-off job may still sit on a free service, available to its staff, exposed in a future breach and covered by an old licence. Free tools rarely promise deletion on a schedule, and some retain backups for long periods. The safest assumption is: *anything you upload to a free tool may exist for as long as the company does.*

A free tool is often a long-term store of short-term data

Breach: the cost no one budgets for

If a free tool is breached, your data is exposed in someone else's incident. You may not be told promptly, or at all. Where personal data is involved and you are the controller, you have your own duty to assess the incident and, if it is a notifiable breach, to inform the regulator within 72 hours of becoming aware.[11] A small vendor with no support line and no contract makes that hard. Chapter 11 sets out what to do.

CHAPTER 4

Browser Extensions: The Biggest Blind Spot

Ben, Marlowe & Finch's designer, installed a grammar extension in his browser eight months ago. It is free, it has a high rating, and it quietly fixes his spelling in every text box he types into. It has also, as far as Nadia can tell from the permissions screen, been allowed to "**read and change all your data on all websites**".

That includes the studio's client portal, the accounting login, the webmail and the project board. Nobody decided that. Ben clicked "Add to Chrome".

An extension sits inside the browser, where everything you do passes through

Why extensions are different

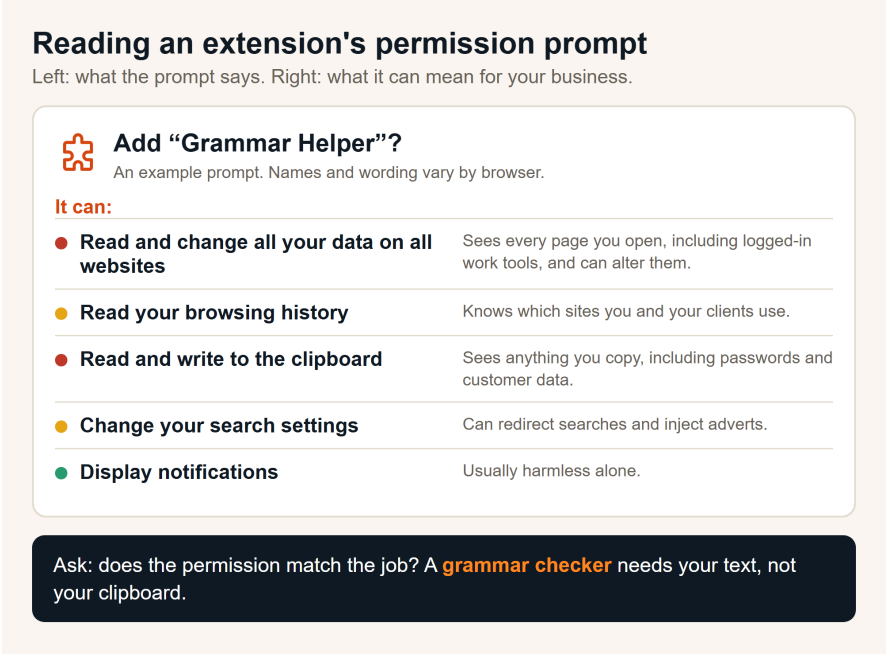
A browser extension is a small program that runs inside your browser with permissions you grant at install time. Useful extensions need to touch the pages you view: a password manager fills your login form, a grammar checker reads your text, a coupon tool watches your shopping. That same access, in the wrong hands, is a spy.

Three things make extensions a special risk for businesses:

1. They sit where the data is. Most business work now happens in a browser: email, documents, CRM, accounting, banking, chat, AI tools. An extension with broad permissions can see all of it, after you have logged in, with no need to break any password.

2. Permissions are broad and little understood. The common broad permission is access to "all websites" or "all URLs". It lets the extension read page content, capture what you type and modify what you see.[17] Most people click through a permissions prompt in a second.

3. They change after you install them. An extension updates itself silently. The version you vetted last year is not the version running today. Extensions are also sold, inherited or hijacked, and a trusted extension can become a harmful one without any change in how it looks.



Reading an extension's permission prompt

Four stories to learn from

An extension sold to a new owner (2020 to 2021). *The Great Suspender* was a popular Chrome extension that suspended unused tabs to save memory. Its original developer sold it in 2020. The new owner shipped updates that asked for more permissions, loaded code from remote servers and added tracking. In early 2021 Google removed the extension from its store and disabled it in browsers where it was installed. Millions of users had trusted a tool whose ownership had quietly changed.[5]

A trusted security vendor's extension, hijacked (December 2024). Attackers phished a developer at a data-security company and used the access to publish a malicious update of its browser extension. The bad version was live for roughly a day and was reported to have affected hundreds of thousands of browsers; security researchers linked the incident to a wider campaign against developers of Chrome extensions. The lesson was uncomfortable: even an extension from a security company is only as safe as its developer's account.[6]

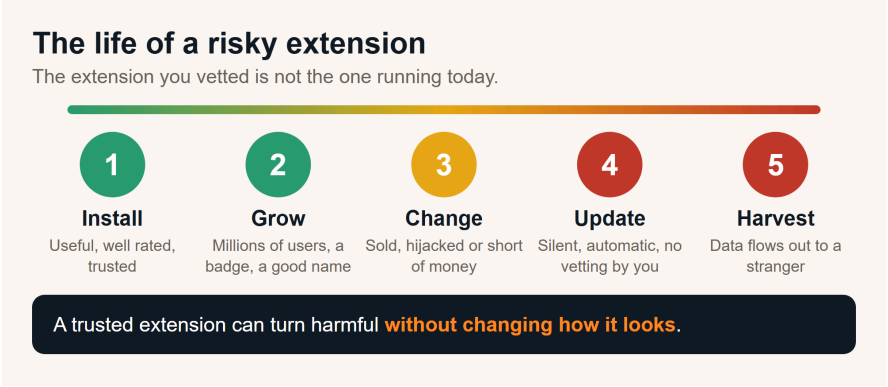
A free VPN that read your AI chats (2025). Researchers reported that a very popular free VPN extension, with a high rating and a "featured" badge in the store, had been updated to capture users' conversations with AI chatbots and send them to its operator's servers, whether or not the VPN was switched on. The privacy policy had mentioned the practice, in language few users would read. For any business whose staff paste client information into AI assistants, this is exactly the risk the whole of this chapter is about.[7]

An antivirus extension that sold browsing history (to 2020). As Chapter 3 described, an antivirus company's browser products collected browsing data and sold it on. The regulator's complaint noted that the collection was dressed up as protection.[4]

None of these was a lone criminal in a hoodie. They were ordinary-looking products, with high ratings, that had a business model, an owner change or a compromised account behind them.

> **The rule.** A browser extension is software you let read your work, installed by someone who may leave, updated by someone you have never met. Treat it as a supplier with full access, not as a sticker on the toolbar.

How a trusted extension goes bad



The life of a risky extension

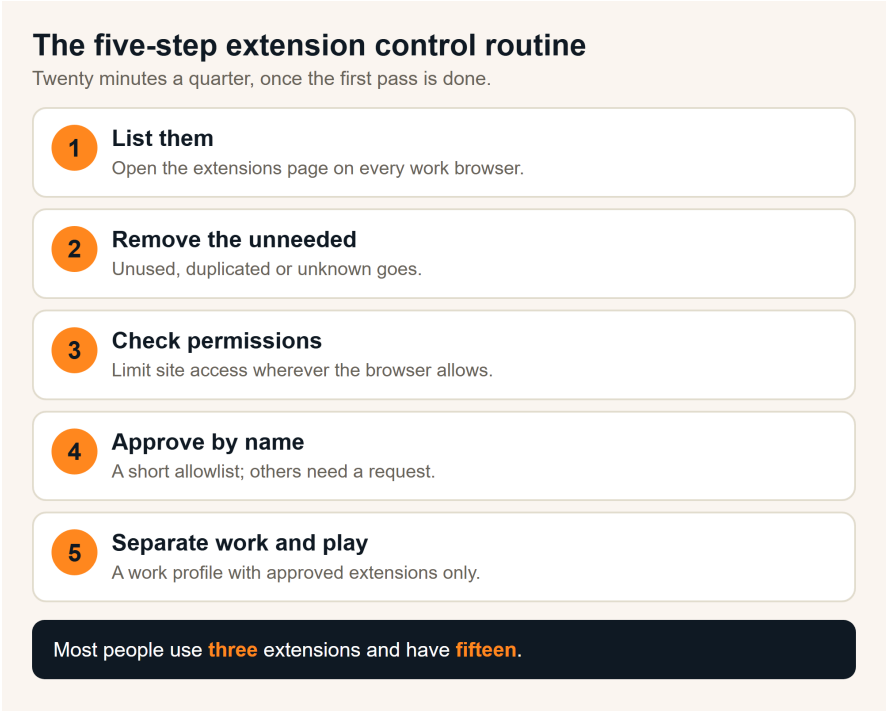
Extensions turn harmful along a handful of routes:

- **Sale or transfer.** The developer sells the extension, with its users, to a new owner.
- **Account takeover.** An attacker steals the developer's store credentials and publishes a malicious update.
- **Monetisation drift.** The developer, short of money, adds tracking, affiliate injection or data sales.
- **Malicious from the start.** The extension is built to look useful and collect data, and passes the store's checks.
- **Abandonment.** The developer stops updating, and a vulnerability stays open.

The browser stores run automated and manual reviews and remove many bad extensions. They also, as the cases above show, miss things and sometimes act late. A store badge is not an audit.

What to do about extensions

You do not need to ban every extension. You need to control them.



The five-step extension control routine

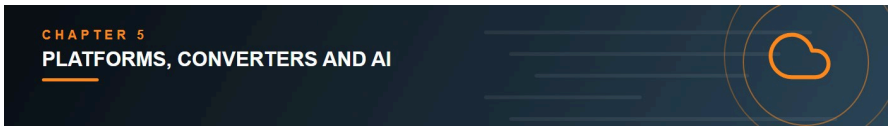
1. **List them.** On every work browser profile, open the extensions page and write down what is installed. In Chrome and Edge it is the Extensions page in the menu. Appendix B gives a one-page audit sheet.
2. **Remove the unnecessary.** Anything unused, duplicated or unknown goes. Most people use two or three extensions and have fifteen.
3. **Check the permissions.** For each one you keep, ask whether "all websites" is really needed. Where the browser lets you limit access to "on click" or to specific sites, do so.
4. **Approve by name.** Agree a short allowlist of approved extensions. Everything else needs a request. Business-grade browser management, such as the policy controls built into Chrome and Edge for managed devices, can enforce an allowlist; for very small teams, a written rule and a quarterly check works.

5. **Separate work from play.** Use a dedicated work browser profile with only approved extensions. Keep shopping, coupon and entertainment extensions in a personal profile.

A password manager, an ad blocker with a good reputation and one or two tools your team genuinely needs are a reasonable set. Free "productivity" and "AI assistant" add-ons with broad permissions deserve the most scrutiny, because they are usually designed to read what you read.

CHAPTER 5

Free Platforms, Converters and AI Tools



Not every risky free tool lives in your browser. A second group sits on the web as a service: you upload something, it does a job, and you download the result. Convenient, fast, and usually free.

Online converters and "quick" tools

PDF merge and compress sites, image resizers, background removers, QR-code makers, spreadsheet converters, e-signature pages and file-sharing links all share a pattern: your document leaves your control for the time it takes to process, and sometimes much longer.

There are two separate problems. The first is **privacy**: a document uploaded to an unknown site may be stored, indexed, mined or sold. A contract, a payroll file or a client list uploaded to a free converter has been handed to a company you know nothing about. The second is **security**: some fake converter sites exist to deliver malware. In 2025 the FBI's Denver office warned that criminals were using free online document converters to infect victims' computers and steal information, because the converted file that comes back may contain more than you asked for.[8]

A quick upload is still an upload

Before you use an online tool on a business file, ask whether the tool needs to be online at all. Most office suites, operating systems and desktop PDF applications can merge, compress, convert and sign documents locally, with no upload. If the answer is "it needs the web", use a provider with a name, an address, a privacy policy you can read and, ideally, a business plan.

Free AI assistants and chatbots

Free AI tools are the fastest-growing source of data leakage in small businesses. The pattern is always the same. A member of staff has a long document, a messy email thread or a spreadsheet to analyse. They paste it into a free chatbot because it is quick. The content may include customer names, health details, pricing, source code or legal advice.

Whether this matters depends on the terms of that exact product and tier:

- Some consumer tiers may use conversations to improve models unless you opt out. Business and API tiers generally commit not to train on your data by default, though you must read the current terms, not assume.
- Free tools may retain conversations for a period, and staff may be able to review them.
- A chat history can be shared, indexed or exposed through a shared link if a feature is switched on.
- A browser extension that sits on the chatbot's page, as the Chapter 4 case showed, may see the conversation regardless of the chatbot's own promises.

The fix is not a ban, which staff will ignore. It is a short, clear rule about **what may be pasted where** (Chapter 10), and a paid business tier of one approved assistant so that the safe option is also the convenient one.

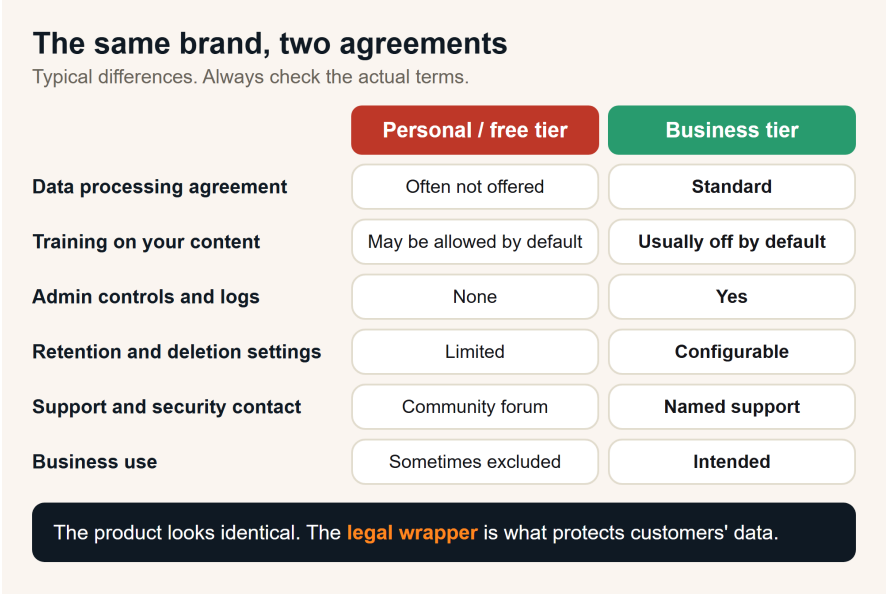
Meeting recorders and note-takers

Tools that join a call, record it and produce a transcript or summary are among the riskiest free tools a business can adopt, for three reasons. They capture **everything** said, including things that were never meant to be written down. They capture **other people's** voices and opinions, who may not know a bot is present or may not agree. And they often reserve the right to use content or derived data to improve the vendor's AI. Check consent, tell participants, and read what the vendor says it does with the audio and the transcript.[3]

Free email, storage and office suites

The big free suites are the most common example of the **mismatch** from Chapter 1. A personal account on a free email and storage service is built for individuals. A business tier of the same service, run under a business agreement, usually adds: a signed data processing agreement, administrator controls, audit logs, retention settings and clearer limits

on how the vendor uses your content. The product looks the same. The legal wrapper is different, and the wrapper is what matters when personal data is involved.



The same brand, two very different agreements

Using a personal account for business is not only a privacy question. It is a continuity problem. When the person who owns the account leaves, you cannot recover the business's files or its email history, and you cannot prove who had access.

Free website, form, survey and marketing tools

Contact forms, newsletter sign-ups, survey tools, live-chat widgets, free analytics, heat maps and social media pixels all place third-party code on your website or collect data from your visitors. They do two things to you at once: they send your customers' data to a third party, and they trigger **cookie and tracking rules**. In Europe, storing or reading information on a visitor's device generally needs consent unless it is strictly necessary, and the courts have confirmed that a website owner can be responsible alongside the tool provider for data

collected through an embedded plug-in.[13] A free analytics tool that sets tracking cookies without a proper consent mechanism is a compliance problem even if it never leaks.

Privacy regulators in Austria and France found in 2022 that use of a popular free analytics service had involved transfers of visitors' data to the United States in a way that breached the GDPR at the time. The legal position on transatlantic transfers has since changed with the EU-US Data Privacy Framework, and it is still being challenged, which is exactly why the choice of tool matters and why you should keep a record of why you chose it.[12][14]

CHAPTER 6

Shadow IT: The Tools Your Team Brought

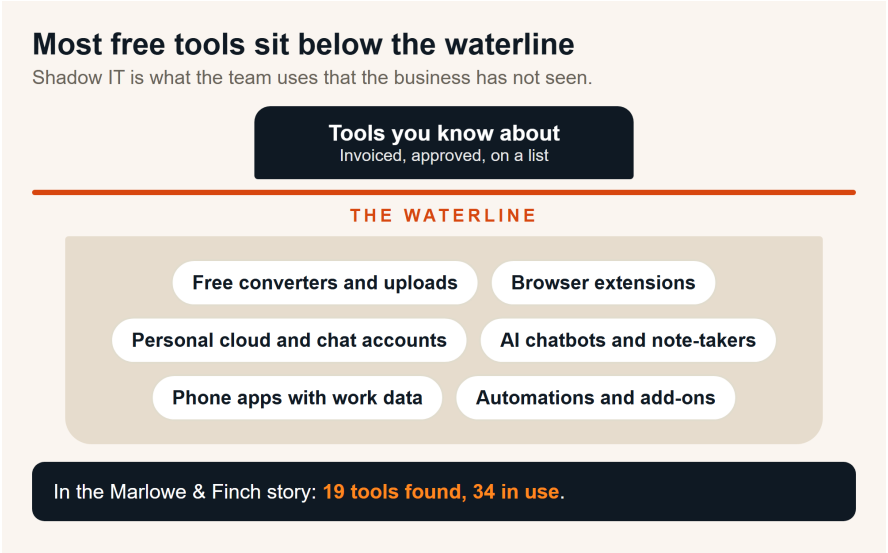
In week three of her audit, Nadia discovered the real problem. She had found nineteen tools by looking at invoices, bookmarks and the admin pages she knew about. When she asked the team directly, the list grew to thirty-four.

Sam in accounts used a free receipt scanner on his phone. Leo, the account manager, had a personal file-transfer account for sending large decks. Two designers had separate free image-generation tools. Someone had set up an automation that copied new leads from the web form into a free spreadsheet add-on. Nobody had hidden anything. Nobody had asked.

What shadow IT is

Shadow IT is any software, service or device used for work without the organisation's knowledge or approval. When the tool is an AI product, it is often called **shadow AI**. It is the rule rather than the exception in small businesses, for good reasons:

- Free tools are quick to adopt: no purchase, no approval, just a sign-up.
- Staff are trying to do their jobs better, and no one has told them which tools are approved.
- Remote and hybrid work moved business onto personal devices and personal accounts.
- There is no IT department to say no, or to say yes with a safer option.



Most free tools sit below the waterline

Why it is a data problem, not a discipline problem

Shadow IT is often framed as staff misbehaviour. That framing makes people hide what they use, which is the worst outcome. The right framing is that **the business has a gap between the tools people need and the tools it has provided**, and staff filled the gap with what was available.

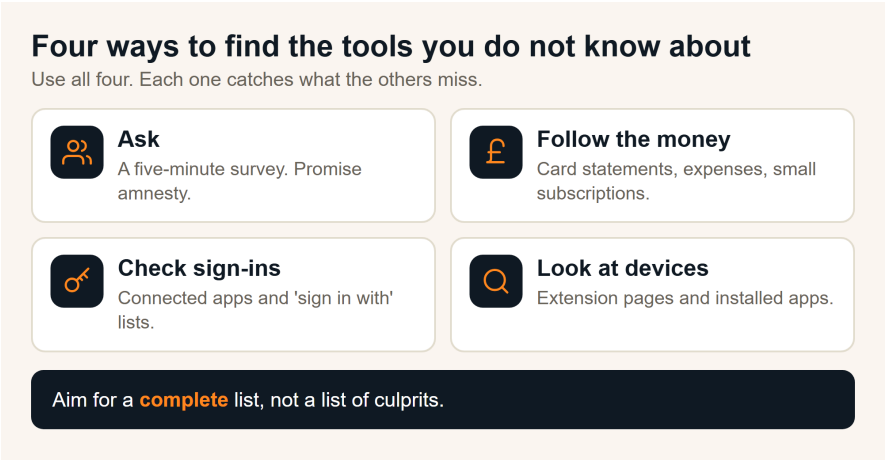
The risks are concrete:

- **Unknown data flows.** You cannot protect, delete or disclose data you do not know is there.
- **No agreements.** There is no data processing agreement with a tool nobody told you about.
- **Orphaned accounts.** When a staff member leaves, their personal accounts keep your files.
- **Duplicated sensitive data.** The same customer list lives in six places, so a rights request or a breach takes six times as long.
- **No monitoring.** Nobody sees the terms change or the security notice arrive.

Finding it without a witch-hunt

You cannot fix what you cannot see. Use four sources, and promise **amnesty** first: the goal is a complete list, not a list of culprits.

1. **Ask.** A five-minute survey: which tools do you use for work, what for, and with what kind of data? Ask also about personal accounts, phone apps and browser extensions.
2. **Follow the money.** Check card statements and expense claims for small subscriptions.
3. **Check sign-ins.** If you use an email or identity platform, look at which third-party apps have been granted access to accounts ("sign in with" and connected-app lists).
4. **Look at the devices.** Open the browser extension pages (Chapter 4) and the installed-apps list on work devices.



Four ways to find the tools you do not know about

Then triage. For each tool found, decide one of four fates, explained in Chapter 10: **approve** it, **approve with conditions**, **replace** it or **remove** it. The goal is not to say no. The goal is that every tool that touches business data has been looked at once, by someone, on purpose.

> **The rule.** You do not have a policy problem until you have a visibility problem. The first control for free tools is a complete list.

CHAPTER 7

What the Law Expects of You

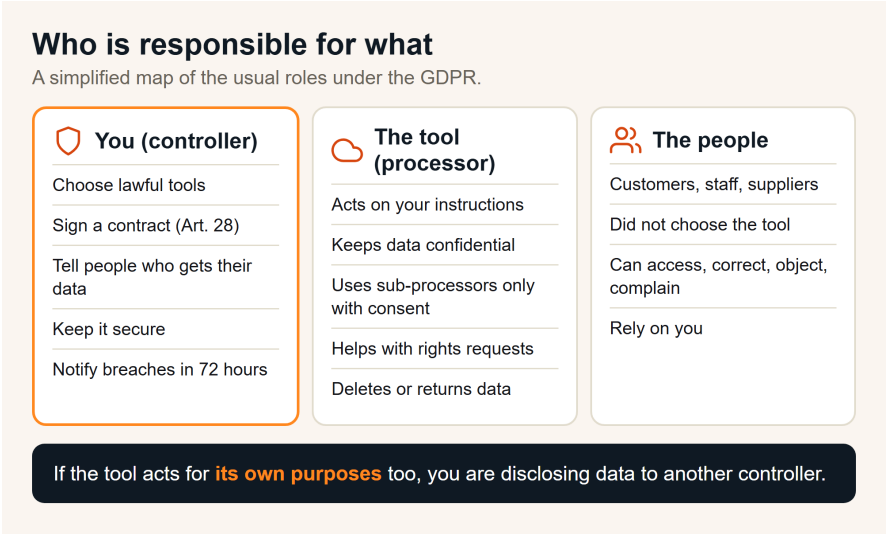
When Nadia sent her tool list to a friend who works in compliance, the reply was short: *"Do you have a processing agreement with any of these?"* She did not. The reply that followed was shorter: *"Then the free part is the least of your problems."*

This chapter is a plain-language map of the rules that most often bite when free tools handle business data. It is an overview for small businesses in Europe and the UK, not legal advice.

The starting point: you are responsible

If you use a tool to handle personal data for your business, you are normally the **controller**: the organisation that decides why and how the data is processed. The tool's provider is usually a **processor**: it handles the data on your behalf.[9] The controller carries the main legal responsibility. That does not change because the tool was free, because an employee signed up for it, or because you never read the terms.

> **The rule.** The price of a tool does not change who is responsible for the data in it. You are.



Who is responsible for what when you use a free tool

The contract: Article 28

When a processor handles personal data for you, the GDPR requires a **written contract** that binds the processor to act only on your instructions, keep the data confidential and secure, use sub-processors only with your authorisation, help you with people's rights requests, delete or return the data at the end, and allow audits.[9] Business tiers of most serious providers include this as a standard "data processing agreement" (DPA). Many free, consumer-tier products do not. If there is no such agreement, you may have no lawful way to put customers' or staff members' personal data into the tool.

A related point: some providers act as **independent controllers** for part of what they do, for example to run advertising or analytics for their own purposes. Then you are not just using a supplier; you are *disclosing* data to another controller, and you need a lawful reason and the right transparency for that disclosure.

Principles that free tools tend to test

The GDPR's core principles are a good checklist for any tool.[10]

- **Purpose limitation.** Data collected for one purpose should not be reused for an incompatible one. If you gave a client's data to a tool to format a report, it should not end up in an advertising profile.
- **Data minimisation.** Share only what is necessary. Pasting a whole customer export into a free AI assistant to ask a simple question fails this test.
- **Storage limitation.** Do not keep data longer than needed. A free tool with no deletion option makes this hard.
- **Transparency.** People must be told who receives their data. Your privacy notice should name categories of recipients, which includes the tools you use.
- **Integrity and confidentiality.** You must keep data secure with appropriate measures.[11] Choosing a supplier with no security commitments is a hard fact to defend.

International transfers

Many free tools are provided by companies outside the EU or UK, or use servers outside them. Sending personal data to a country without an adequacy decision generally needs extra safeguards, such as standard contractual clauses and an assessment. Transfers to US companies that have joined the **EU-US Data Privacy Framework** can rely on the European Commission's adequacy decision of July 2023, which remains subject to legal challenge.[12] In practice, for a small business: find out where the tool processes data, and whether the provider relies on the Framework or on contractual clauses. A reputable provider will say so in its DPA.

Cookies, trackers and embedded tools

Under the ePrivacy rules, storing or accessing information on someone's device, which includes most cookies, pixels and similar technologies, normally requires consent, unless strictly necessary for the service the user asked for.[13] The Court of Justice has held that a pre-ticked box is not valid consent, and that a website operator can be

a joint controller with the provider of an embedded plug-in for the data it collects.[13] If your site uses a free analytics, chat, map or social widget, you share responsibility for what it does to your visitors.

Security, breaches and your 72 hours

You must keep personal data secure, and if a breach occurs you must record it and, unless it is unlikely to result in a risk to people, notify the supervisory authority within **72 hours** of becoming aware of it. Where the risk to individuals is high you must also tell the people affected.[11] This applies to breaches at your suppliers too, because the controller's clock starts when you are aware. A supplier with no obligation to tell you quickly is a supplier who puts you in breach by default.

Staff, monitoring and extensions

Tools that watch what employees do, such as a free productivity tracker or a browser extension that logs activity, raise employment and data-protection questions of their own: transparency, proportionality and, in many countries, consultation. A tool that sees your staff's browsing and messages without their knowledge is not only a security risk; it may be unlawful monitoring.

Confidentiality beyond the GDPR

Data protection is not the only duty. You may owe confidentiality to clients under contracts and non-disclosure agreements, professional-secrecy rules, or sector regulations. Putting a client's confidential material into a tool whose terms let the vendor use or disclose it can breach those agreements even if no personal data is involved. Check client contracts for clauses on subcontractors and approved tools.

What it can cost

Maximum fines under the GDPR are up to €20 million or 4% of annual worldwide turnover for the most serious infringements, and up to €10 million or 2% for others.[15] Those are ceilings, and small businesses are rarely fined near them. The UK GDPR has equivalent ceilings in

pounds.[15][16] The more realistic costs are quieter: a lost client contract, a regulator's order to stop using a tool, an insurer disputing a claim, a customer's complaint, time spent investigating, and the reputational cost of having to say you cannot tell people where their data went.

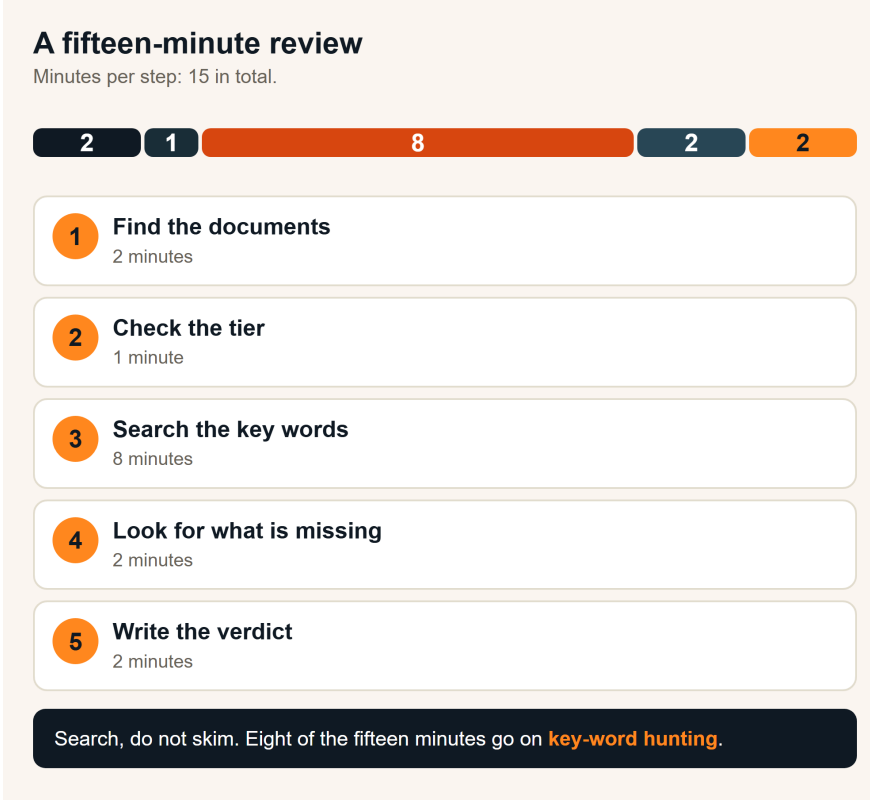
What can go wrong, from least to most serious

CHAPTER 8

Reading the Fine Print in Fifteen Minutes

Nobody reads terms and conditions. This chapter is for the one time it matters: when you are deciding whether a tool deserves a place in your business. You do not need to read every word. You need to read the right parts and recognise the phrases that carry the risk.

The fifteen-minute method



A fifteen-minute review of any tool's terms

1. **Find the right documents (2 minutes).** There are usually three: the **terms of service**, the **privacy policy**, and, for business customers, a **data processing agreement**. Many providers also publish a list of sub-processors and a "trust" or "security" page.
2. **Check which tier the terms cover (1 minute).** Consumer terms and business terms are often separate. Make sure you are reading the ones that apply to you.
3. **Search, don't skim (8 minutes).** Open each document and use your browser's find function for the words in the table below. Read two or three sentences either side of each hit.

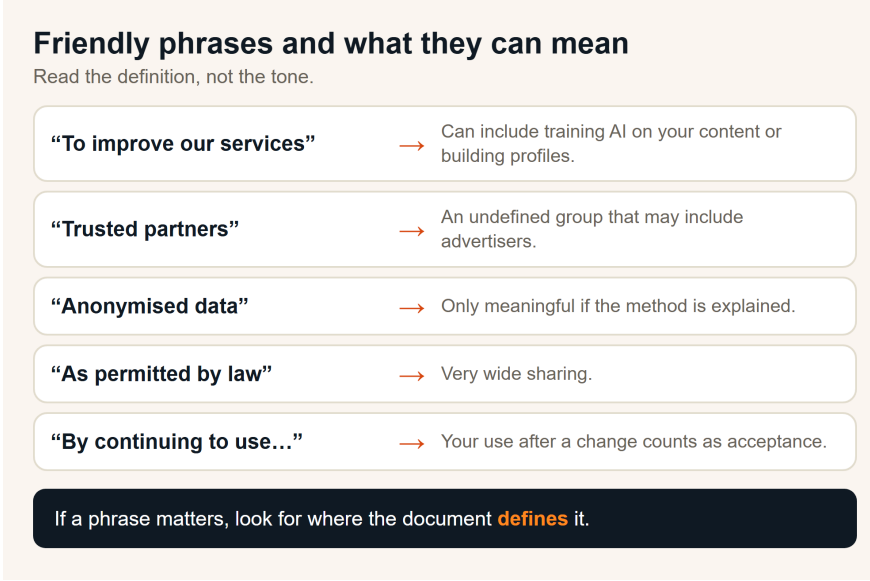
4. **Look for what is missing (2 minutes).** Is there a DPA? A statement of where data is stored? A deletion process? A security contact? A missing item is information.
5. **Write the verdict (2 minutes).** In the register (Appendix A): approve, approve with conditions, replace or remove, with the date and the reason.

Search words and what they reveal

Search for	What to look for	Why it matters
licence / license	A "worldwide, perpetual, irrevocable, sublicensable" licence over your content	The vendor may use your content far beyond running your account, and keep using it after you leave
train / machine learning / improve	Whether your content, prompts or recordings can be used to train or improve models	Your confidential material could become part of a model or a human reviewer's sample
affiliates / partners / third parties	Who receives data and for what	The list may include advertisers and analytics firms
sell / share / "for advertising"	Any sale or sharing for marketing	A red flag for a business tool
anonymous / aggregated / de-identified	Claims that shared data cannot identify anyone	Check how: regulators have found "anonymised" data was not
retain / delete / backup	How long data is kept and whether deletion is real	Data you thought was gone may remain
transfer / servers / location	Where data is stored and processed	Affects transfers and which authorities can demand access
change / modify / "continued use"	How the vendor can change terms and whether you are told	A silent change can swap your protections for new rights
business / commercial / personal use	Whether business use is allowed on this tier	Some free tiers forbid commercial use or exclude business protections
liability / "as is" / indemnify	Caps and exclusions of responsibility	Free tools usually disclaim nearly everything

Search for	What to look for	Why it matters
breach / security incident	A promise to notify you and how fast	Needed to meet your 72-hour clock
export / portability	Whether you can get your data out in a usable form	Determines how locked in you are

Phrases that sound harmless



Friendly phrases and what they can mean

Some wording is designed to be read as comfortable and means more than it seems.

- **"We take your privacy seriously."** A promise of sentiment, not a commitment.
- **"To improve our services."** Can include training AI on your content and building profiles. Check whether the document defines it.
- **"Trusted partners."** Undefined group that may include advertisers.
- **"Anonymised data."** Only meaningful if the method is explained. Look for "aggregated" and "de-identified" as well.
- **"We may share with third parties as permitted by law."** Very wide.

- **"By continuing to use the service you agree."** Your use after any change counts as acceptance.

Free versus business: the five differences that matter

When you compare a tool's free and business tiers, five differences are usually the real value of the paid plan:

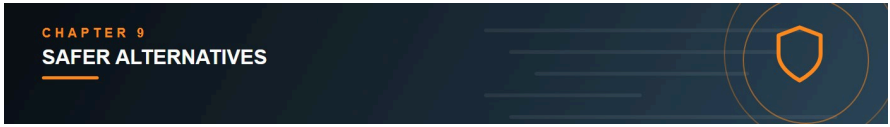
1. **A data processing agreement** and clearer roles.
2. **No training on your data by default**, or an opt-out you control centrally.
3. **Administrator controls**: who can sign in, share, export and install add-ons.
4. **Retention and deletion settings**, with logs.
5. **Support and a security contact**, so you have someone to call.

If a vendor has no paid tier, that is information too. It means the free product is the whole business, and you should know how it is funded.

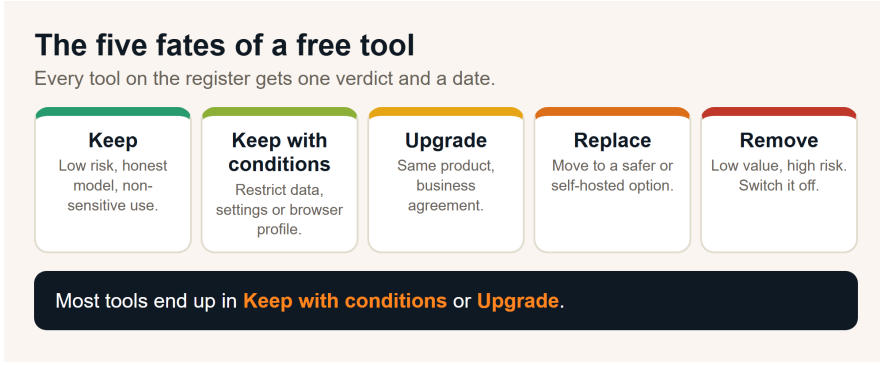
> **The rule.** You are not looking for a perfect policy. You are looking for no surprises: nothing in the document that you would not be comfortable explaining to your most sensitive client.

CHAPTER 9

Safer Alternatives



Having found the risks, the practical question is what to use instead. The answer is almost never "spend a fortune". It is a short set of choices.



The five fates of a free tool

Five options for any tool

1. Keep it. Some free tools are fine as they are: well-funded by paying customers, honest about their model, collecting little, and used for non-sensitive work. Note it in the register and review it annually.

2. Keep it, with conditions. Use it, but restrict what goes into it. For example: approved for internal drafts only, never for client data; used in a work browser profile with the extension locked down; AI features switched off; personal data banned.

3. Upgrade to the business tier. Often the most cost-effective fix. The product stays the same while the legal terms improve: a DPA, training opt-outs, admin controls and support. For common tools the extra

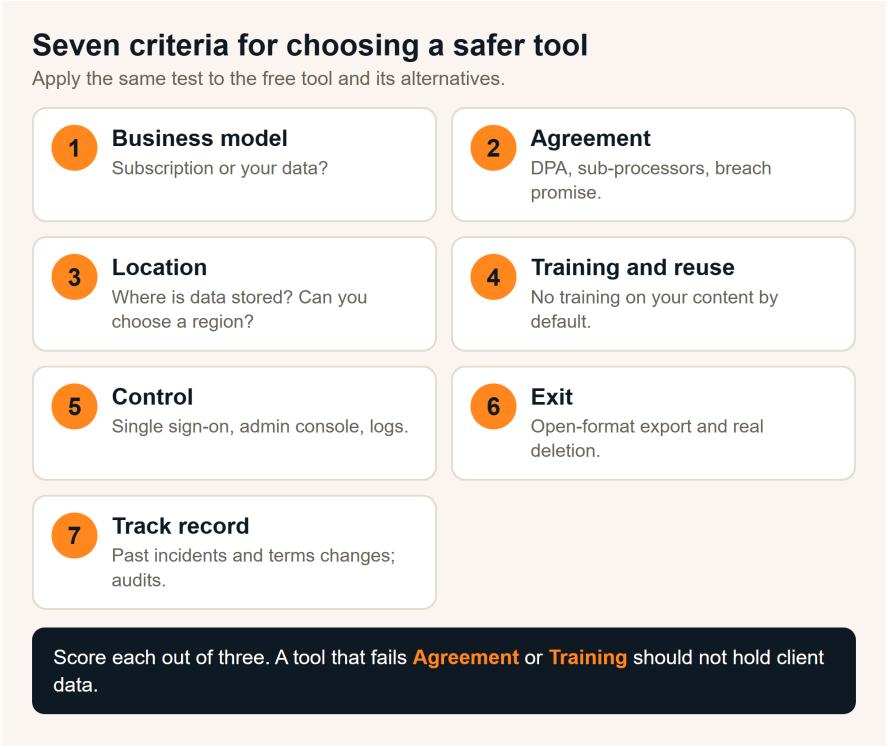
cost is typically a few pounds or euros per user per month, which is small beside the cost of one data incident. Check current prices.

4. Switch to a privacy-friendly or self-hosted alternative. Replace the tool with one whose business model does not depend on your data: open-source software, a European provider under European law, or software you run yourself.

5. Stop using it. If the tool's value is low and its risk is high, remove it. Many free tools are used by one person for a task that a built-in feature could do.

Choosing alternatives: seven criteria

Whatever you choose, test it against the same seven questions.



Seven criteria for choosing a safer tool

1. **Business model.** Does it earn from subscriptions or from your data?

2. **Agreement.** Is there a DPA, a clear list of sub-processors and a breach-notification promise?
3. **Location.** Where is the data stored and who can access it? Is there a way to choose an EU or UK region?
4. **Training and reuse.** Does it commit not to use your content to train models or build profiles?
5. **Control.** Single sign-on, admin console, audit log, retention settings?
6. **Exit.** Can you export everything in an open format and have it deleted?
7. **Track record.** How has the vendor handled incidents and terms changes before? Is it independently audited (for example, a recognised security certification)?

Starting points by category

The table gives *types of option* and a few well-known examples to show what each looks like. These are examples, not endorsements or recommendations: products, owners and terms change, so check each one against the seven criteria before you adopt it.

Job	Risky pattern	Safer pattern	Examples of the type
Email and calendar	Personal free account used for business	Business tier under a DPA, or a European provider	Business plans of major suites; privacy-focused providers
Documents and files	Personal cloud drive, free file-transfer links	Business cloud storage, or self-hosted	Business tiers; self-hosted file-sync platforms
Office editing and PDFs	Upload-to-convert websites	Desktop software that works offline	Open-source office suites; offline PDF tools
Passwords	Browser-saved passwords, shared spreadsheets	A reputable password manager with a team plan	Password managers with business plans or open-source options
Analytics	Free tracker that profiles visitors	Privacy-focused analytics, cookie-light or self-hosted	Open-source or EU-hosted analytics

Job	Risky pattern	Safer pattern	Examples of the type
Meetings and notes	Free recorder bots joining calls	Built-in recording under your business agreement, with notice	Approved meeting tool's own transcript
Messaging	Personal chat apps for client work	A business chat tool under a DPA, or an end-to-end encrypted app	Team chat on business plans; encrypted messengers
AI assistants	Free consumer chatbot	Business tier or enterprise agreement with no-training terms	Paid business plans from major AI providers
Forms and surveys	Free form builder with broad terms	Form tool with DPA, or your own site form	Form tools with business plans; open-source form builders
VPN	Free VPN extension	Paid VPN from an audited provider, or none (use your firm's secure access)	Audited paid providers

Open source and self-hosting: honest trade-offs

Open-source and self-hosted tools remove the hidden business model, but they bring responsibilities. Someone has to update the software, back it up and secure it. For a firm with no technical person, a **managed** open-source service (a company that runs it for you under a contract) can be the best of both. A neglected self-hosted server can be riskier than a well-run free product. Self-host only if you can maintain it.

A word on cost

The commercial argument is simple. A business tier of a few tools may cost a few hundred pounds a year. One mishandled data incident can cost many times that in lost time, client trust and advice, before any fine. Sensible spending is concentrated: pay for the **three or four tools that hold your most sensitive data** (email and files, your AI assistant, your meetings and notes, your password manager), and keep the rest free but governed.

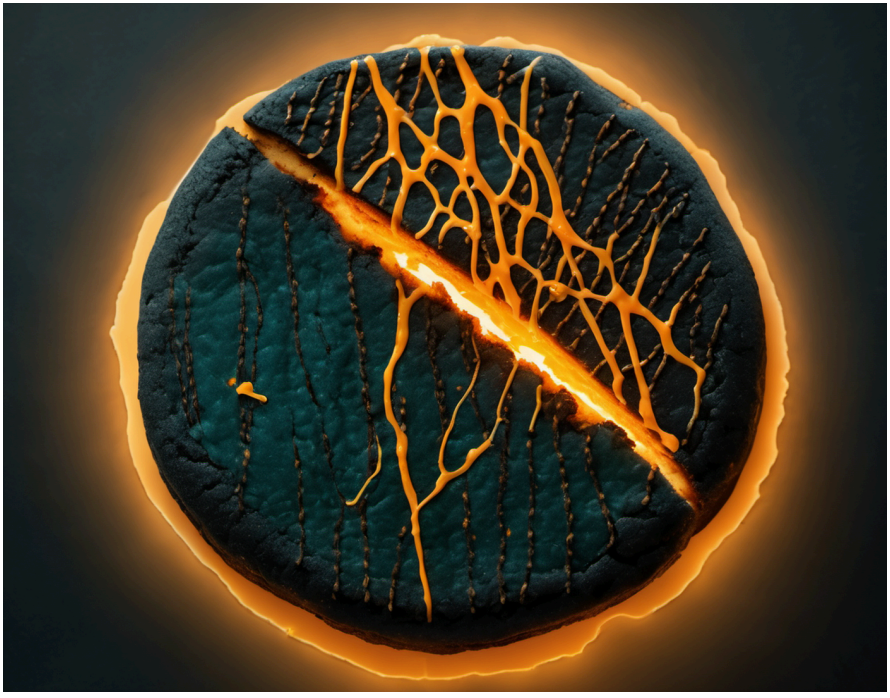
Paying for the few tools that hold your most sensitive data buys the most protection

CHAPTER 10

A Simple Tool Policy

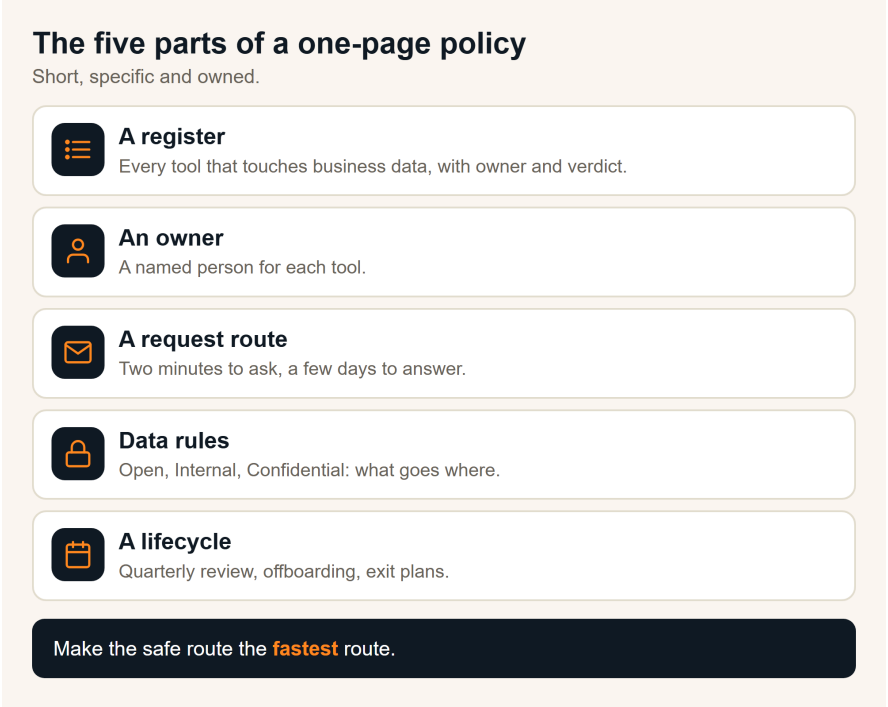
Marlowe & Finch ended up with a policy that fits on one page, a register with twenty-six tools in it, and a rule that anyone can request a new tool in under two minutes. Staff stopped hiding what they used because the answer was usually "yes, with conditions" rather than "no".

A policy for free tools has one job: make the safe path the easy one. It does not need to be long. It needs to be **specific, short and owned**.



A cookie is a small thing. So is a permission. Both add up

The five parts of a one-page policy



The five parts of a one-page tool policy

1. A register. One list of every tool that touches business data: what it is, who owns it, what data it sees, which tier, when you last reviewed its terms, and the verdict. This is the single most useful control in the book. Appendix A is a template.

2. An owner for each tool. A named person who knows why it is there, receives its notices, reviews its terms once a year and can switch it off. When that person leaves, ownership is reassigned before their access is removed.

3. A request route. A short, fast way to ask for a new tool: a form or a message to one person. State the three questions you will ask (what is it for, what data will it see, what is the model) and promise an answer within a few days. If getting a yes takes weeks, staff will go around the process.

4. Data rules. Say, in plain words, what may go where. Three tiers are enough:

Class	Examples	Free consumer tools
Open	Published material, public research, draft headlines	Allowed
Internal	Internal plans, non-sensitive drafts, supplier names	Only approved tools
Confidential	Customer or staff personal data, client files, contracts, financials, credentials	Only business-tier tools with a DPA

Add one hard line: **never paste passwords, payment-card numbers, health information or unpublished client documents into any tool that has not been approved for that class.**

5. A lifecycle. Tools are added, reviewed, and removed. Review the register every quarter (twenty minutes), and on every staff departure and every notice of changed terms. Include an exit plan for each important tool (Appendix F).

Browser and device rules

- Use a **dedicated work browser profile**, signed in only to work accounts.
- Extensions: approved list only (Chapter 4). Check the list quarterly.
- No work data in **personal** cloud accounts or messaging apps.
- Keep devices and browsers updated, and use screen locks and device encryption.
- Where you manage devices, turn on the browser's managed-extension policy so only approved extensions can be installed.

AI rules

The pattern from Chapter 5 deserves its own short rule:

- Use only the **approved AI assistant**, on the business tier, for anything above "Open".

- Never paste **Confidential** data into any consumer-tier AI tool, free or paid, unless it has been approved for that purpose.
- Turn off meeting-recorder bots unless the host has told all participants and the tool is approved.
- If in doubt, remove names and details before pasting, or ask first.
- Anyone who uses AI tools for work should have basic training in what they can and cannot do; in the EU this is also a legal expectation for businesses that deploy AI.[18]

Make training short and human

A policy no one remembers does not protect anyone. Run a fifteen-minute session at the start, with three real examples from this book: an extension that changed hands, a converter that carried malware, a meeting bot that kept a transcript. Then repeat a two-minute reminder each quarter. People follow rules they understand, from people who explain why.

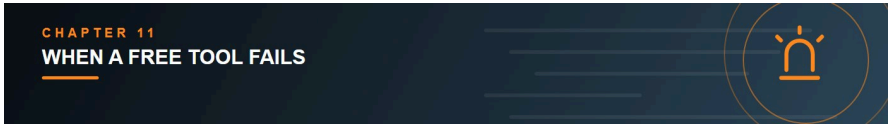
> **The rule.** Staff do not break policies because they do not care. They break them because the policy was slower than the problem. Make the safe route faster.

Offboarding: the forgotten control

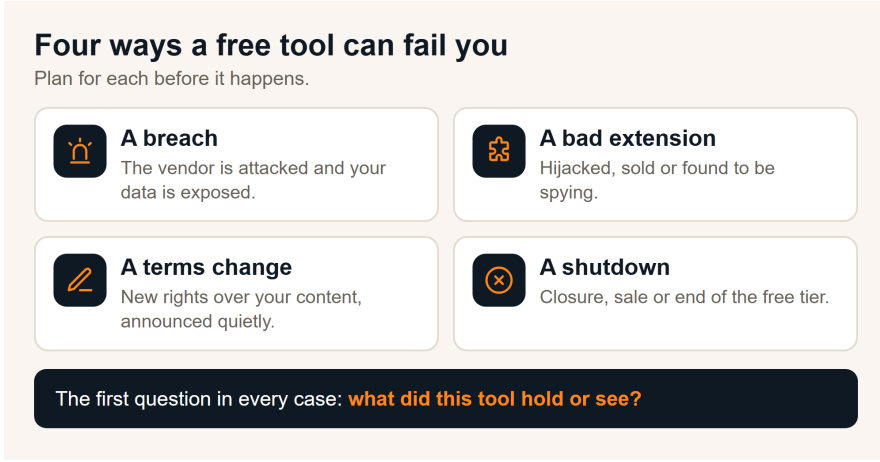
When someone leaves, three things often stay behind: their personal accounts holding business files, their browser extensions and saved sessions, and the tools they alone owned. Add a checklist to every departure: transfer ownership of each tool, move files out of personal accounts, remove their access, and reset shared credentials.

CHAPTER 11

When a Free Tool Goes Wrong



It will happen to someone. A tool you use is breached, an extension is found to be harvesting data, a vendor changes its terms overnight, or a service is shut down with thirty days' notice. What matters is whether you have a plan.

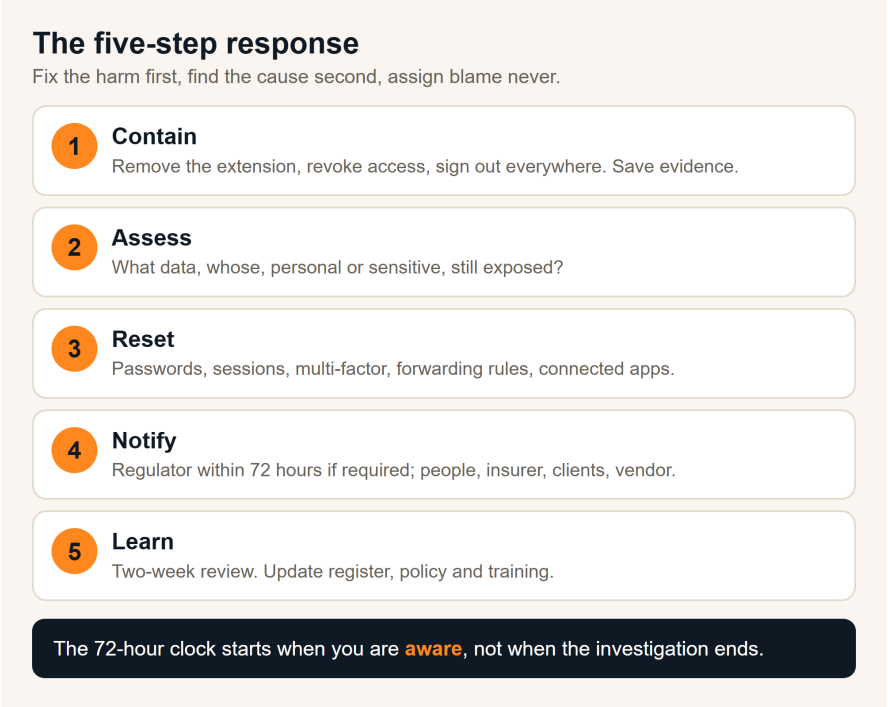


Four ways a free tool can fail you

Four kinds of failure

1. A breach. The vendor suffers a security incident and your data is exposed. **2. A compromised or malicious extension.** An extension you use is hijacked, sold or found to be spying. **3. A terms change.** The vendor widens its rights or starts using content in a way you have not agreed to. **4. A shutdown or acquisition.** The service closes, is bought, or retires its free tier.

The five-step response



The five-step response when a free tool fails

Step 1: Contain. Stop the leak first. Remove the extension, revoke the tool's access to your accounts, sign out of all sessions, and pause use. Take screenshots and save notices before they disappear.

Step 2: Assess. What data did the tool hold or see? Whose is it? Was it personal data? Is it special-category data? Is the exposure ongoing? For an extension, assume everything the browser displayed while it was installed was visible.

Step 3: Reset. Change passwords and revoke sessions for every account that was open in the affected browser. Turn on multi-factor authentication where it is not already enabled. Check email forwarding rules and connected apps for anything you did not set up.

Step 4: Notify. Decide who needs to know. If personal data is involved and the incident is notifiable, tell your regulator within 72 hours of becoming aware. Tell affected people if the risk to them is high. Tell

your insurer, your clients if their contracts require it, and the vendor. Keep a written record of what you decided and why, even if you decide not to notify.[11]

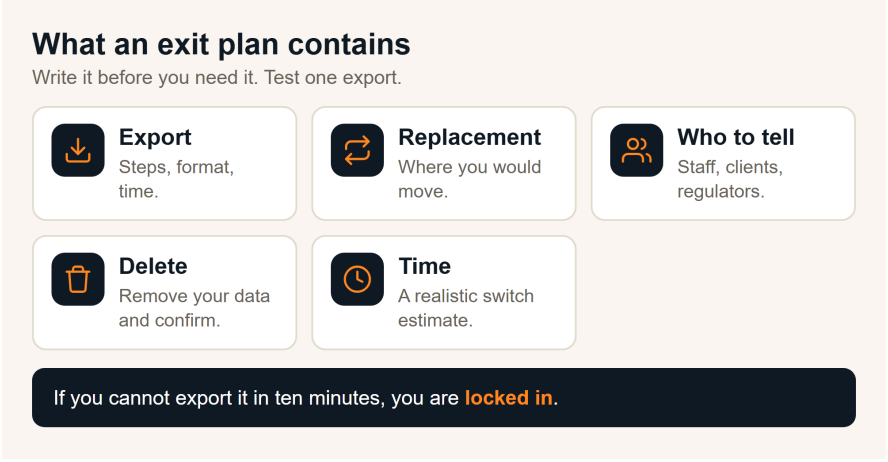
Step 5: Learn. Within two weeks, review what happened. Update the register, tighten the policy, remove or replace the tool, and tell the team what you changed.

> **The rule.** In an incident, the best evidence of good practice is a record made at the time. Log what you knew, when, and what you did.

Having an exit plan before you need one

An exit plan is the answer to the question "*what if we had to stop using this tomorrow?*" For each tool that holds important data, write down:

- how to **export** everything, and in what format;
- where the **replacement** would come from;
- who must be **told** (staff, clients, regulators);
- how to **delete** your data and confirm that it is gone;
- how long the **switch** would realistically take.

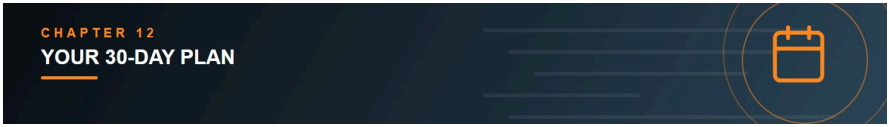


What an exit plan contains

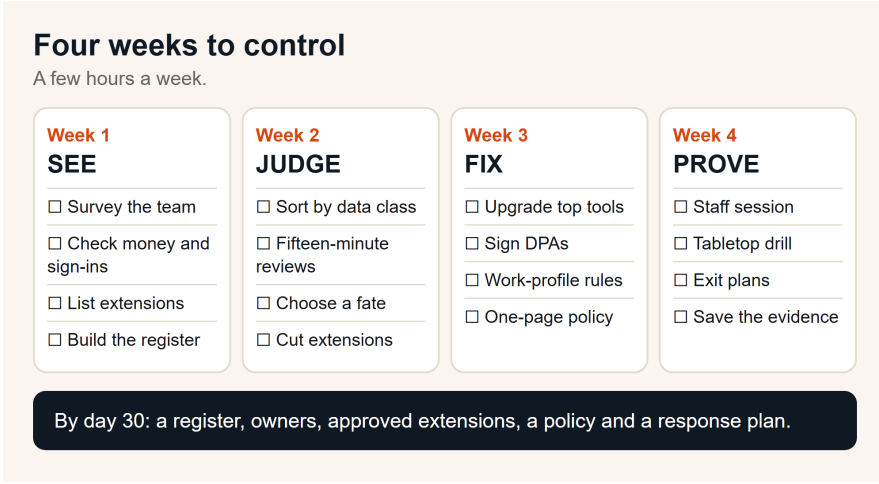
Test it for your one or two most important tools. Exporting a file takes ten minutes and tells you whether you are locked in.

CHAPTER 12

Your 30-Day Free Tool Plan



You do not need a project team. You need a few hours a week for a month. By day 30 you will have a register, owners, an approved set of browser extensions, a one-page policy and a way to respond when something goes wrong.



Four weeks to control over your free tools

Week 1: See

- ☐ Announce the review, and promise amnesty: you want a complete list, not a list of culprits.
- ☐ Send the five-minute survey to every team member (what tools, for what, with what data, on which devices and accounts).
- ☐ Check card statements, expense claims and connected apps for subscriptions and sign-ins.

- ☐ Open the extensions page in every work browser and write down what is installed.
- ☐ Build the register (Appendix A).
- ☐ Name an owner for each tool and mark who has not yet got one.

Week 2: Judge

- ☐ Sort tools by the data they see: Open, Internal, Confidential.
- ☐ Review the terms and privacy policy of every tool that sees Internal or Confidential data using the fifteen-minute method.
- ☐ Mark each tool: approve, approve with conditions, replace, remove.
- ☐ Remove the unused and unknown extensions. Limit the permissions of those you keep.
- ☐ Identify the three or four tools where an upgrade to a business tier would remove the most risk.

Week 3: Fix

- ☐ Upgrade or replace the top-priority tools and sign data processing agreements.
- ☐ Move work out of personal accounts into business accounts.
- ☐ Set the browser rules: work profile, approved extensions only.
- ☐ Write the one-page policy (Appendix D) and the AI rules.
- ☐ Update your privacy notice and record of processing so they list the tools you use.

Week 4: Prove

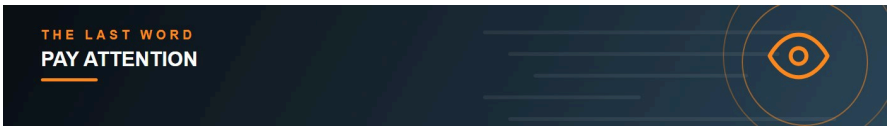
- ☐ Run a fifteen-minute staff session with real examples.
- ☐ Run a tabletop drill: "an extension we use was found to be harvesting data". Walk the five-step response.
- ☐ Write exit plans for your two most important tools and test one export.
- ☐ Put the quarterly review in the calendar.

- [ ] Save the evidence: register, terms reviews, signed agreements, policy, training date.

Time spent looking is cheaper than time spent explaining

By day 30 you should be able to answer a client's tool questionnaire in an afternoon. Marlowe & Finch did, and they won the charity's work a second year running.

Conclusion: Pay Attention



The cheapest software in your business may be the most expensive decision you have made without noticing.

Free tools are not the enemy. Some are generous, honest and excellent. But "free" describes your invoice, not the arrangement. Behind every free product is a business model, a set of rights over your data and a company whose interests may or may not match yours. The only way to know which is to look.

You now know how to do that. You can ask who is paying and for what. You can see what a tool collects and where it goes. You can spot the extension with too much power, the converter that is really a trap, the meeting bot that nobody told the client about. You can read the fine print in fifteen minutes, choose a safer option, and run a one-page policy that keeps the useful tools and drops the risky ones.

Start small. Make the list. Name the owners. Check the extensions. Upgrade the three tools that matter most. Everything else follows from knowing what you are running.

You will never have zero risk. You can, however, stop paying with things you did not know you were spending.

APPENDIX A

Free Tool Register

Copy one row per tool. Review quarterly and whenever terms change.

#	Tool and vendor	What it is used for	Data it sees (Open / Internal / Confidential)	Tier	Owner	DPA signed?	Terms reviewed (date)	Verdict
1								
2								
3								
4								
5								
6								
7								

APPENDIX B

Browser Extension Audit

Complete one sheet per work browser profile. Verdicts: **Keep**, **Limit** (restrict site access), **Replace**, **Remove**.

Extension	Who installed it and why	Developer / publisher	Permissions (all sites? clipboard? tabs?)	Last updated	Needed?	Verdict

Checks for each extension:

- ☐ Do we still use it every week?
- ☐ Does the permission list match what it claims to do?
- ☐ Is the publisher a real company with a website, a privacy policy and a support route?
- ☐ Has the owner or name changed recently?
- ☐ Is there a built-in feature or a trusted desktop tool that does the same?

Reviewed by: _____ **Date:** _____ **Next review:** _____

APPENDIX C

Fine-Print Checklist

Complete in fifteen minutes for any tool that will see Internal or Confidential data.

- ☐ I have the right document set: terms, privacy policy, DPA, sub-processor list.
- ☐ I am reading the terms for the tier we will use.
- ☐ Business use is permitted on this tier.
- ☐ The licence over our content is limited to running our account.
- ☐ Our content is **not** used to train models or build profiles by default, or we can switch it off centrally.
- ☐ No sale or sharing of our data for advertising.
- ☐ Sub-processors and partners are listed, and we have checked them.
- ☐ Storage location is stated, and transfers are covered (adequacy or standard clauses).
- ☐ There is a deletion process and a stated retention period.
- ☐ The vendor promises to notify us of a breach and says how fast.
- ☐ We can export our data in a usable format.
- ☐ Changes to terms are notified to an owner we can name.
- ☐ A data processing agreement is available and signed.

Tool: _____ **Reviewer:** _____ **Verdict:** _____ **Date:** _____

APPENDIX D

One-Page Tool Policy Template

Adapt the wording to your business. Fill every blank.

1. Purpose. This policy keeps our business and customer data safe when we use free and low-cost tools, extensions and online platforms.

2. Register. All tools that touch business data are listed in the Free Tool Register. Owner of the register: _____. Reviewed every _____.

3. New tools. Ask _____ before using a new tool for work. Expect an answer within _____ working days. Do not enter Internal or Confidential data into an unapproved tool.

4. Data classes. Open data may go in any tool. Internal data only in approved tools. Confidential data only in business-tier tools with a signed data processing agreement.

5. Never. Never paste passwords, payment-card numbers, health information or unpublished client documents into any tool not approved for that purpose.

6. Browsers. Use the work browser profile. Install only extensions on the approved list: _____. Request others from _____.

7. AI tools. The approved assistant is _____. Do not use consumer-tier chatbots for Internal or Confidential data. Bots may not join meetings without the host announcing them.

8. Accounts. Use work accounts for work. Do not store business files in personal accounts.

9. Leaving. When someone leaves, transfer their tools and files and remove access on their last day.

10. Problems. Report anything suspicious at once to _____. No blame for honest reports.

Approved by: _____ **Date:** _____ **Next review:** _____

APPENDIX E

Free-versus-Paid Questionnaire

Send to a vendor, or answer from its public documents, before you decide whether to upgrade.

Question	Free tier	Business tier
Is a data processing agreement available?		
Is our content used to train or improve AI models?		
Can we opt out centrally?		
Where is data stored? Can we choose a region?		
Who are the sub-processors?		
How long is data retained after deletion?		
Do you notify us of a breach? How fast?		
Is there an admin console and audit log?		
Can we export all data in open formats?		
What support is included?		
What does it cost per user per month?		

Decision: _____ **Decided by:** _____ **Date:** _____

APPENDIX F

Exit Plan

One per important tool. Complete before you need it.

Item	Answer
Tool and owner	
What data it holds	
How to export (steps, format, time)	
Replacement option	
Who must be told	
How to delete our data and confirm	
Realistic switch time	
Last tested (date)	

APPENDIX G

Free Tool Incident Log

Date	Tool	What happened	Data involved	Action taken	Notified (who, when)	Lessons

Glossary

Adequacy decision. A finding by the European Commission that a country or framework gives personal data an essentially equivalent level of protection, allowing transfers without extra safeguards.

Browser extension. A small program that adds features to a web browser and can read or change the pages you visit, depending on the permissions granted.

Controller. The organisation that decides why and how personal data is processed.

Data broker. A company that collects personal data from many sources and sells or licenses it to others.

Data processing agreement (DPA). A contract that binds a processor to handle personal data only on the controller's instructions, as required by Article 28 GDPR.

Fingerprinting. Identifying a device or user by combining technical details, such as browser, fonts and screen size, without using cookies.

Freemium. A model where a basic version is free and paid tiers fund the product.

Metadata. Data about data: who communicated with whom, when and from where, rather than the content itself.

Processor. An organisation that processes personal data on behalf of a controller.

SDK. A software development kit, a bundle of third-party code built into an app or website, often for analytics or advertising.

Shadow IT / shadow AI. Software or AI tools used for work without the organisation's knowledge or approval.

Sub-processor. A further supplier engaged by a processor to help handle personal data.

Telemetry. Automatic reports of how software is used and performs, sent back to the vendor.

Tracking pixel. A tiny, usually invisible image or script that reports a visitor's activity to a third party.

A Note on GDPRGard.eu

Choosing and governing tools sits beside a wider question: what does the GDPR expect of a small business? If this book has raised questions about records of processing, data processing agreements, privacy notices or cookie banners, GDPRGard.eu offers free tools, guides and articles written in plain language for small businesses. Look there for checklists you can use alongside the templates in this book.

About the Author

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy is not a barrier to ambition but a foundation of trust, and that business owners should not need a legal degree to understand the rules that apply to them.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex European rules into simple steps, checklists and templates that busy people can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Visit **gdprgard.eu** for free tools, articles and updates, including notes on changes to the rules covered in this book. If this guide helped you, an honest review where you bought it helps other readers find it.

Notes and Sources

Research cut-off: 30 October 2026. Items marked (read) were consulted for this edition through news and trade commentary; the others rest on the author's working knowledge of well-known public records and should be re-checked against the primary source before you rely on them.

1. Zoom Video Communications, terms of service update and subsequent clarification on AI and customer content, August 2023 (read, through press coverage including Axios and Dark Reading). Dates in secondary sources differ; check the archived terms.
2. WeTransfer, terms of service change of July 2025 and withdrawal of the AI references, 15 July 2025 (read, through press coverage; the current terms should be checked on the vendor's site).
3. Brewer v. Otter.ai, Inc., US District Court, Northern District of California, filed 15 August 2025. Allegations only; the company denies wrongdoing; status should be checked against court records (read, through NPR and law-firm commentary).
4. US Federal Trade Commission, Avast Limited and Jumpshot: order announced February 2024 and finalised June 2024; $16.5 million; prohibition on selling or licensing browsing data for advertising (read, through trade press and law-firm commentary; check ftc.gov).
5. The Great Suspender, Chrome extension: sold in 2020, removed from the Chrome Web Store in early February 2021 (read, through press coverage; reports of malware were disputed in part and the buyer was not publicly identified).
6. Cyberhaven, Chrome extension compromise of 24 to 26 December 2024; security vendor's incident statement and independent analyses (read, through vendor and security-press reports; counts of affected users differ between sources).
7. Koi Security research on the Urban VPN Proxy browser extension and AI chatbot conversations, reported December 2025 (read, through Dark Reading, CSO Online and BankInfoSecurity coverage; the operator's response and any regulatory action should be checked).
8. FBI Denver Field Office, public warning on malicious free online document converter tools, 7 March 2025 (read, through press coverage).

9. GDPR (Regulation (EU) 2016/679), Articles 4(7) and 4(8) (controller and processor), 24, and 28 (processor contracts); EDPB Guidelines 07/2020 on the concepts of controller and processor. eur-lex.europa.eu; edpb.europa.eu.
10. GDPR Article 5(1) (principles), Article 6 (lawfulness), Articles 13 and 14 (information to be provided).
11. GDPR Article 32 (security), Articles 33 and 34 (breach notification); EDPB Guidelines 9/2022 on personal data breach notification.
12. GDPR Chapter V (Articles 44 to 49); European Commission Implementing Decision (EU) 2023/1795 of 10 July 2023 on the EU-US Data Privacy Framework. Legal challenges to the Framework continue; check their current status.
13. Directive 2002/58/EC (ePrivacy), Article 5(3); Court of Justice of the EU, Case C-673/17, Planet49 (1 October 2019); Case C-40/17, Fashion ID (29 July 2019).
14. Austrian Data Protection Authority (DSB) decision on Google Analytics (published January 2022) and the French CNIL decision of February 2022 on the same subject.
15. GDPR Article 83 (administrative fines). In the UK, the UK GDPR and Data Protection Act 2018 provide equivalent maximum fines of £17.5 million or 4% and £8.7 million or 2%.
16. UK GDPR, Data Protection Act 2018 and the Privacy and Electronic Communications Regulations 2003 (PECR) for UK businesses; Information Commissioner's Office guidance on cookies and similar technologies and on data sharing.
17. Chrome extension documentation: permissions and host permissions ("all URLs") and the Chrome Web Store developer policies (developer.chrome.com). Check the current versions; browser vendors change extension rules over time.
18. AI Act (Regulation (EU) 2024/1689), Article 4 (AI literacy), applicable from 2 February 2025, for businesses that deploy AI tools.